



Criptografía y Seguridad

Seguridad en la empresa

Gobernanza (Governance)

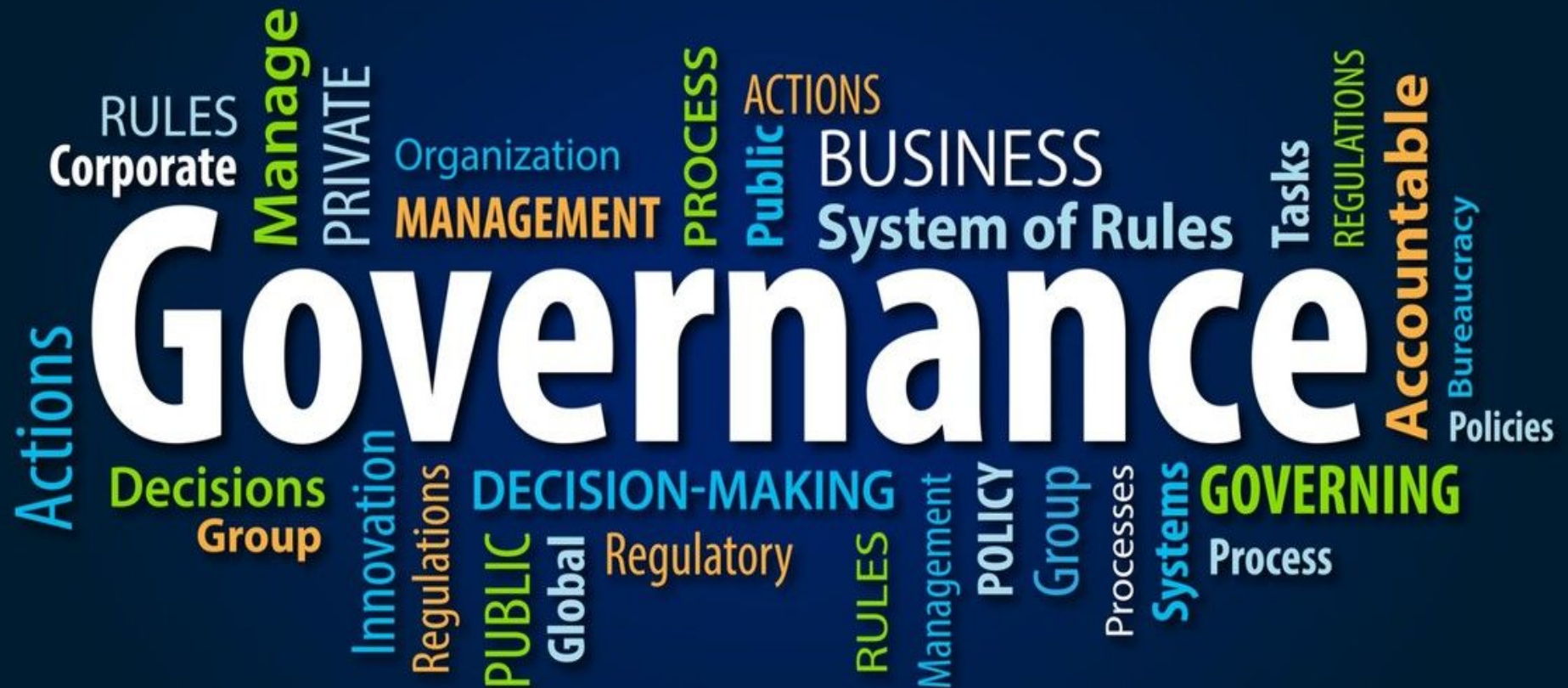
- Definición
 - Conjunto de procesos, políticas y controles implementados para gestionar y mitigar riesgos en la organización.
 - Establecimiento de responsabilidades y roles dentro de la entidad para garantizar la protección de la información.
- Importancia en la organización
 - Asegura la confidencialidad, integridad y disponibilidad de la información.
 - Protege contra amenazas cibernéticas y violaciones de seguridad.
 - Fomenta la confianza de clientes y stakeholders.

Gobernanza (Governance)

- **Objetivos Principales:**
 - Alinear la estrategia de seguridad con los objetivos del negocio.
 - Reducir los riesgos y mitigar los impactos de los incidentes de seguridad.
 - Cumplir con las regulaciones y normativas aplicables.
 - Crear una cultura de seguridad dentro de la organización.



Governance

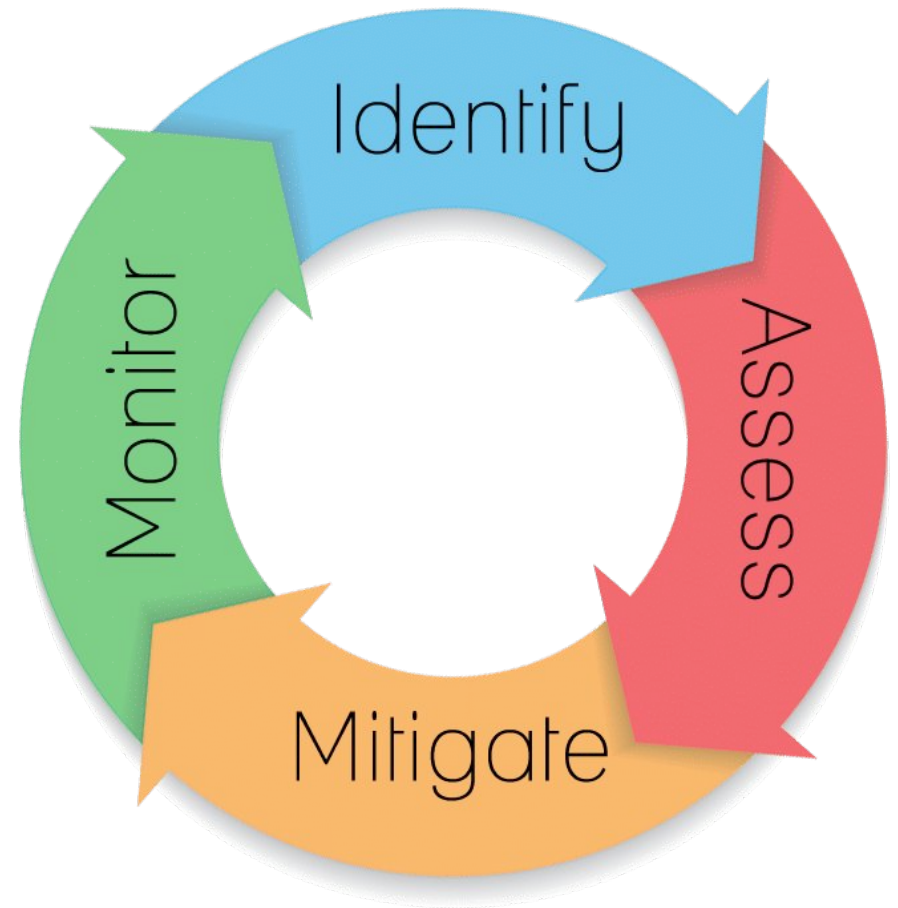


Risk Management

¿Qué es la Gestión de Riesgos?

Identificación, evaluación y control de amenazas potenciales para el negocio.

Minimización del impacto de incidentes de seguridad en el negocio.



Risk Management

Identificación del riesgo

Identificación de los activos críticos para el negocio

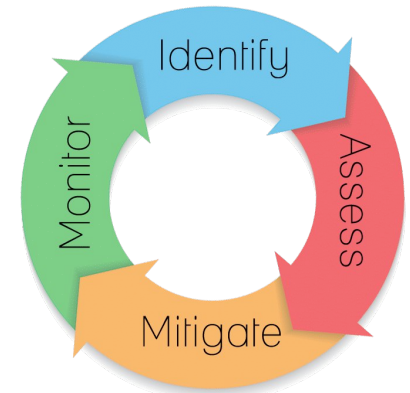
¿Qué puede afectar al ciclo de negocio?

Involucra:

- Datos
- Sistemas
- Infraestructura
- Personas

Identificación de riesgo potenciales

- Malware
- Ataques externos
- Errores humanos
- Sabotaje
- Ambientales



Risk Management

Evaluación del riesgo

Se debe identificar probabilidad de ocurrencia y el impacto en el negocio.

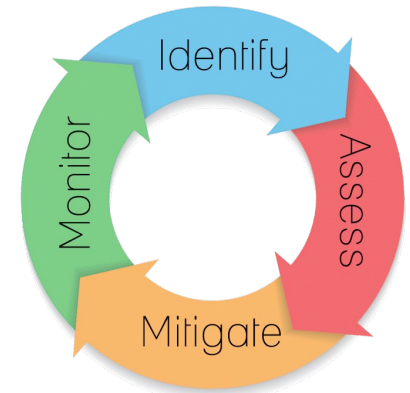
Se debe realizar evaluaciones externas de seguridad (Red Team/PenTest)

Se clasifican los riesgo según su impacto

Alto

Medio

Bajo



Risk Management

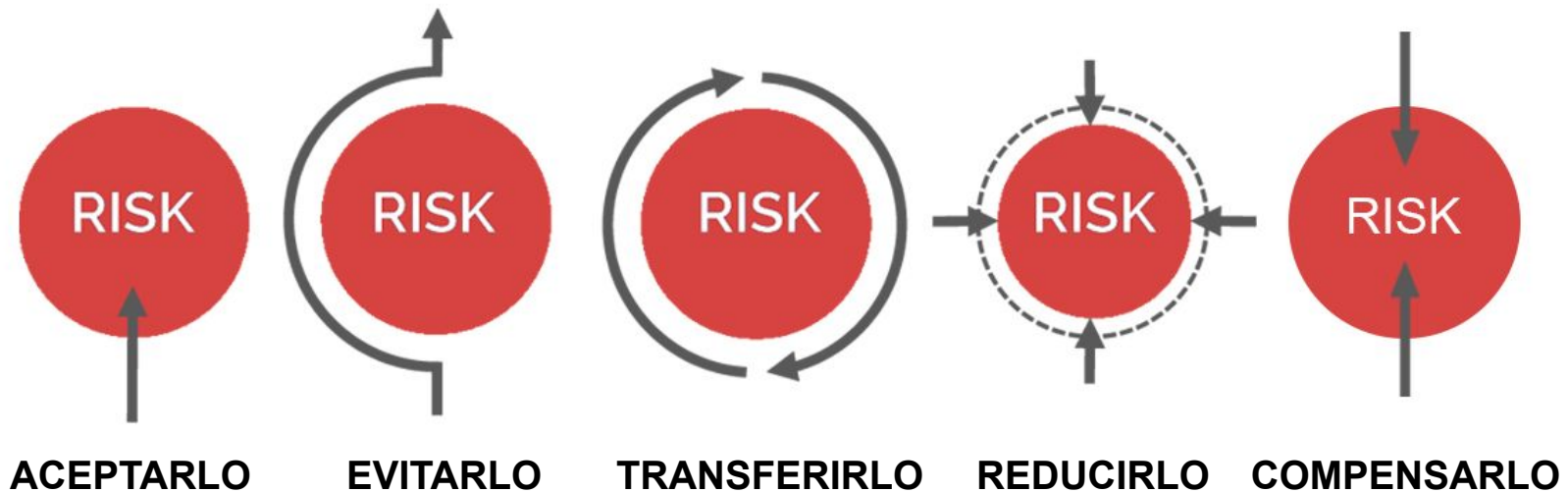
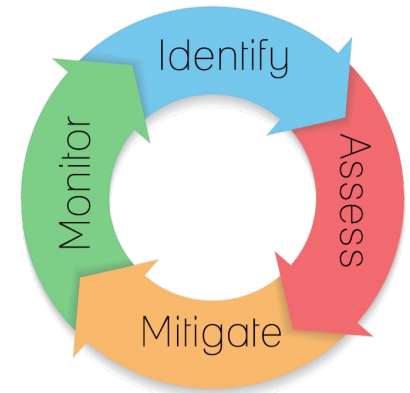
Mitigación del riesgo

Elaboración políticas de gestión.

Se definen y evalúan procedimientos de operación y acción ante incidentes.

Se diseñan y prueban planes de acción ante la ocurrencia del incidente.

Se capacita al personal a todo nivel.



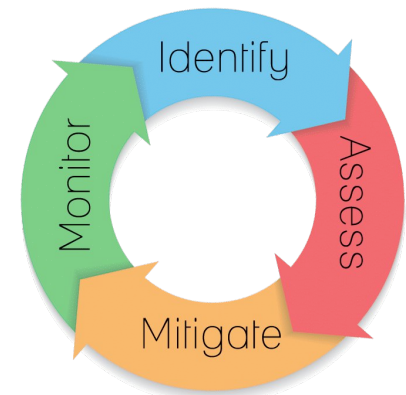
Risk Management

Monitoreo y Evaluación

Elaboración y supervisión de controles y medidas de seguridad.

Auditorías internas y externas.

Simulaciones de ataques e incidentes.



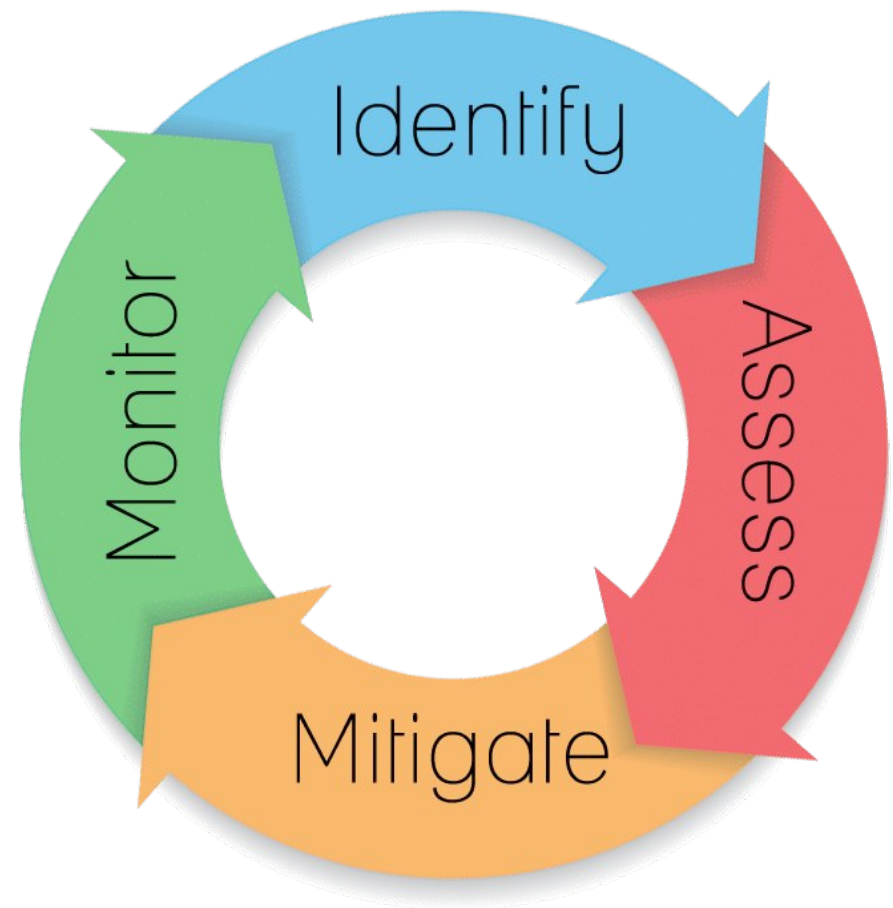
Foundational

Risk Management

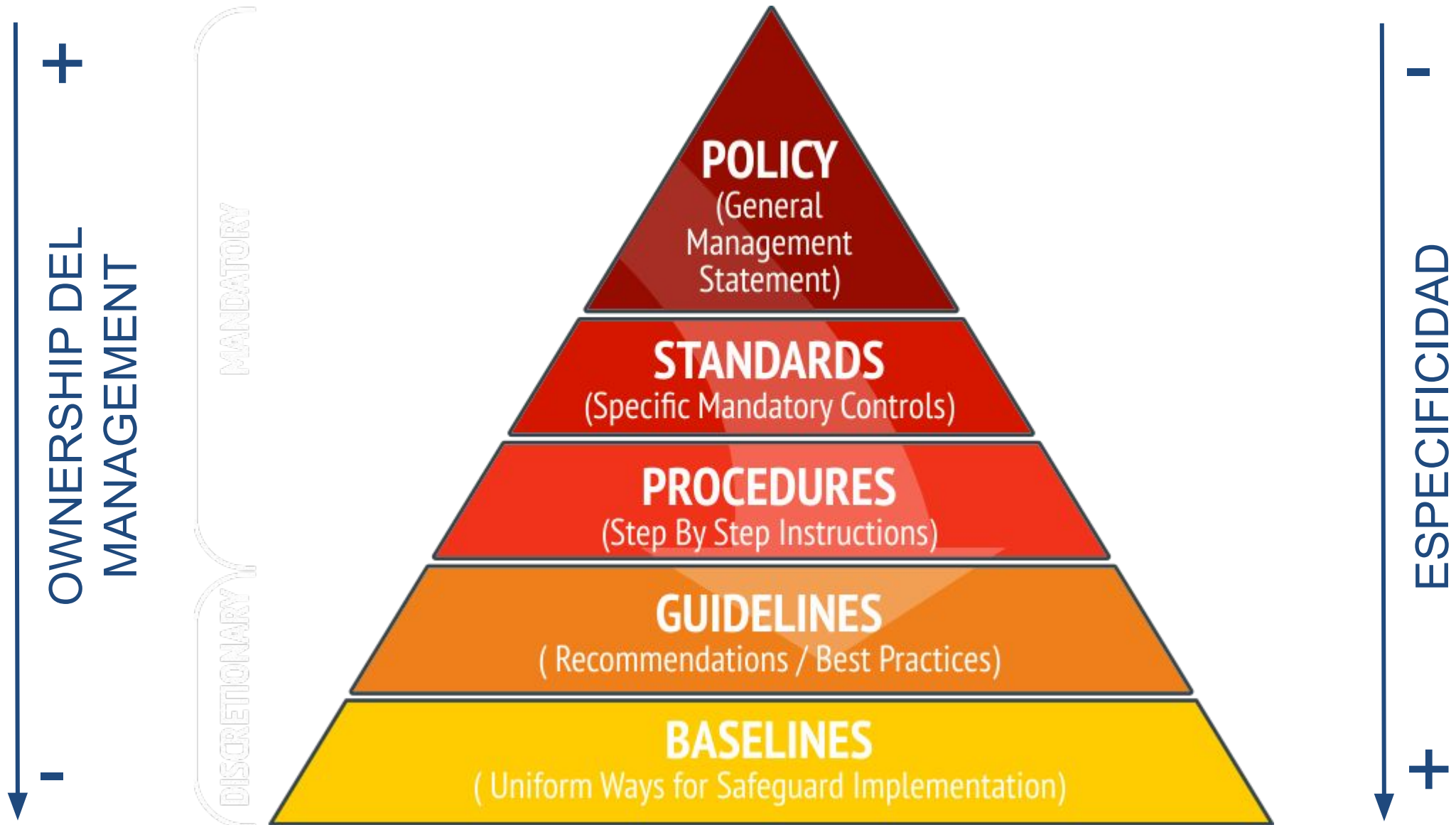
La **gestión de riesgos** es **fundamental** para proteger la información.

Un **enfoque proactivo** reduce la probabilidad y el impacto de incidentes.

La **revisión y adaptación continua** es esencial para enfrentar nuevos desafíos.



Políticas de Seguridad



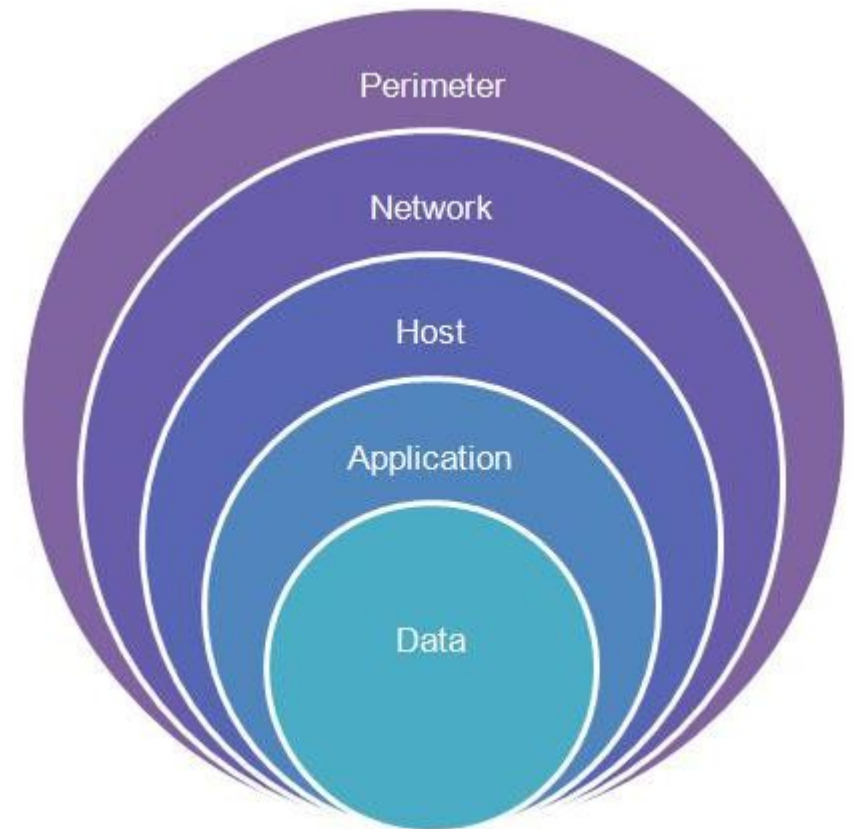


Criptografía y Seguridad

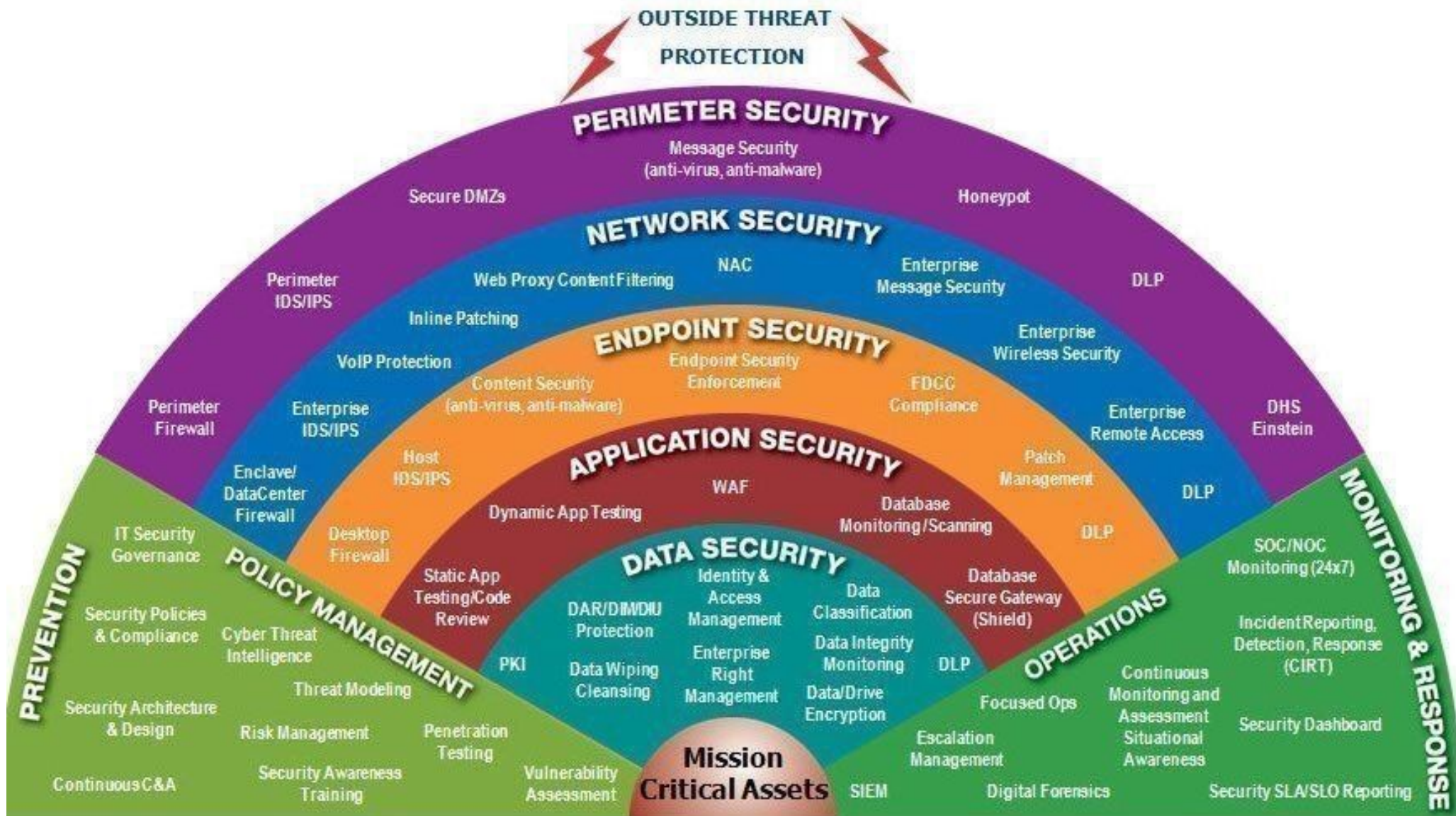
Estrategias

Defense-in-depth

- Define el concepto de proteger como asegurar la confidencialidad, integridad y accesibilidad de la información.
- Es una estrategia de seguridad que aplica múltiples capas de defensa para proteger los activos de la organización.
- Busca crear redundancia en caso de que una medida de seguridad falle.



Defense-in-depth



Principios de Defence-in-depth

- **Diversificación:**
 - Utilización de diversas tecnologías y métodos de defensa.
- **Redundancia:**
 - Implementar múltiples capas que se superpongan para asegurar la protección continua.
- **Segmentación:**
 - Dividir la red en segmentos controlados para limitar el acceso no autorizado.
- **Monitoreo:**
 - Visibilidad de todas las capas de defensa
 - Correlación de eventos para la detección de ataques

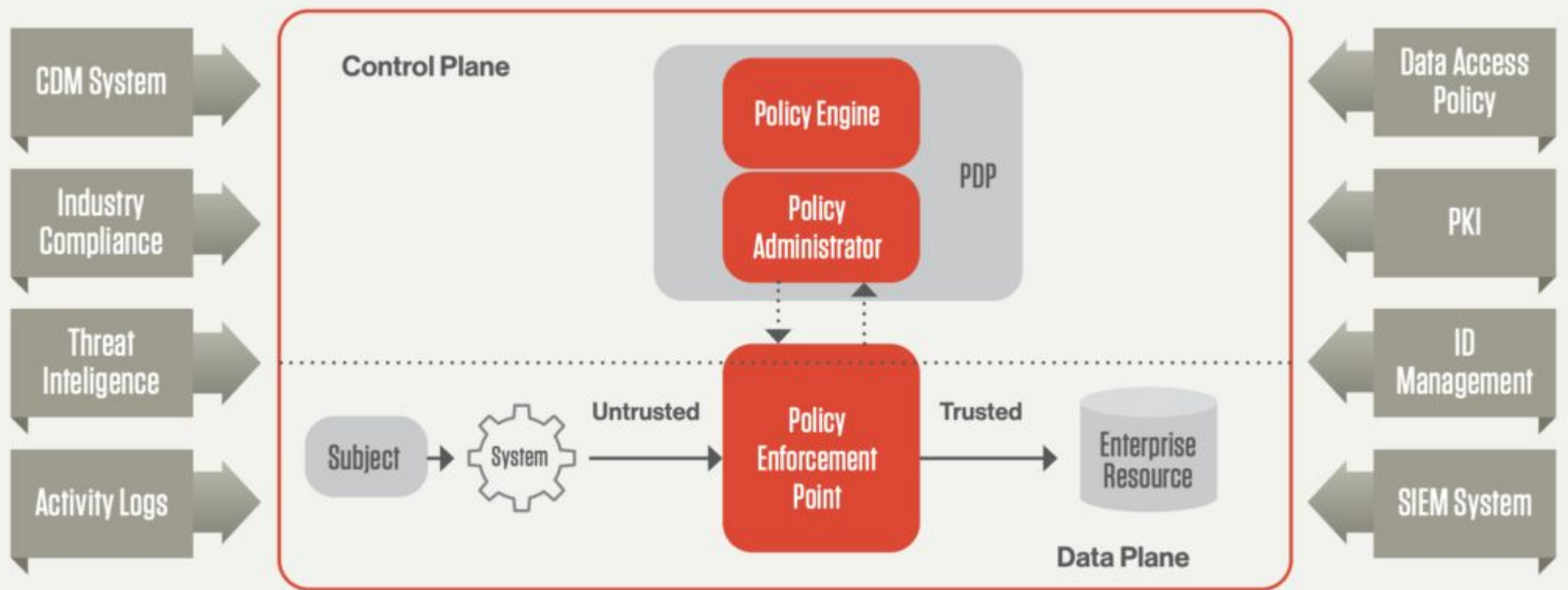
Problemas de Defence-in-depth

- Altos costo
 - De tecnología (Diversos proveedores de tecnologías)
 - De capacitación y operación.
 - De monitoreo. Se recolecta muchos datos pero se les saca poco valor.
- No resuelve eficientemente los problemas de ataques internos.
- Difícil de implementar cuando los sistemas y procesos que intentamos proteger están distribuidos.
 - Data centers híbridos (propios-terceros)
 - Múltiples proveedores de nube
 - Empresas cloud native.

Zero Trust Architecture (ZTA)

- La Arquitectura de Confianza Cero (Zero Trust Architecture, ZTA) es un modelo de seguridad que asume que las amenazas, tanto internas como externas, están presentes en la red en todo momento.
- Objetivo
 - Proteger la integridad, la confidencialidad y la disponibilidad de los datos y recursos de una organización.
- Principios Básicos:
 - Nunca confíes (Never Trust).
 - Siempre verifica” (Always Verify).
 - Asume que has sido atacado (Assume breach).

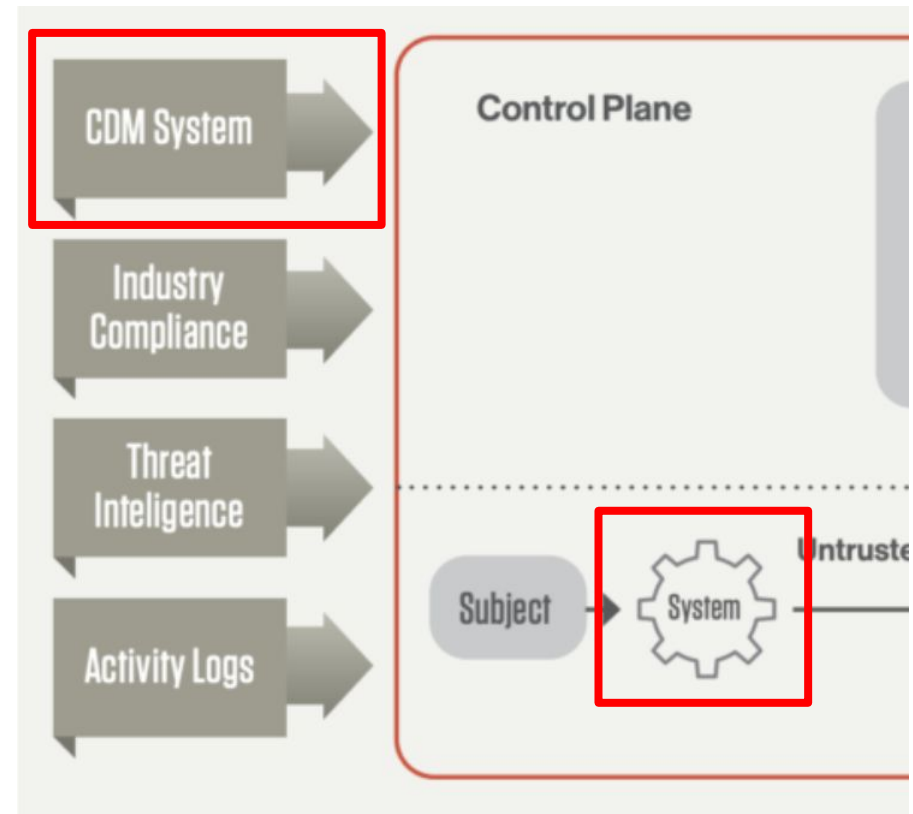
Componentes de ZTA



NIST 800-207 Zero Trust Framework

Componentes de ZTA

- Sistema de Diagnóstico y Mitigación Continuos (CDM)
 - Un sistema CDM de una empresa proporciona al motor de políticas la información sobre el activo que realiza una solicitud de acceso
 - Tiene el antivirus actualizado?
 - Últimos updates de seguridad?



Componentes de ZTA

- Sistema de cumplimiento de la industria (Industry compliance)
 - garantiza que la empresa cumpla con los regímenes normativos a los que pueda atenerse.
 - HIPAA, Banco Central, SOX, PCI



Componentes de ZTA

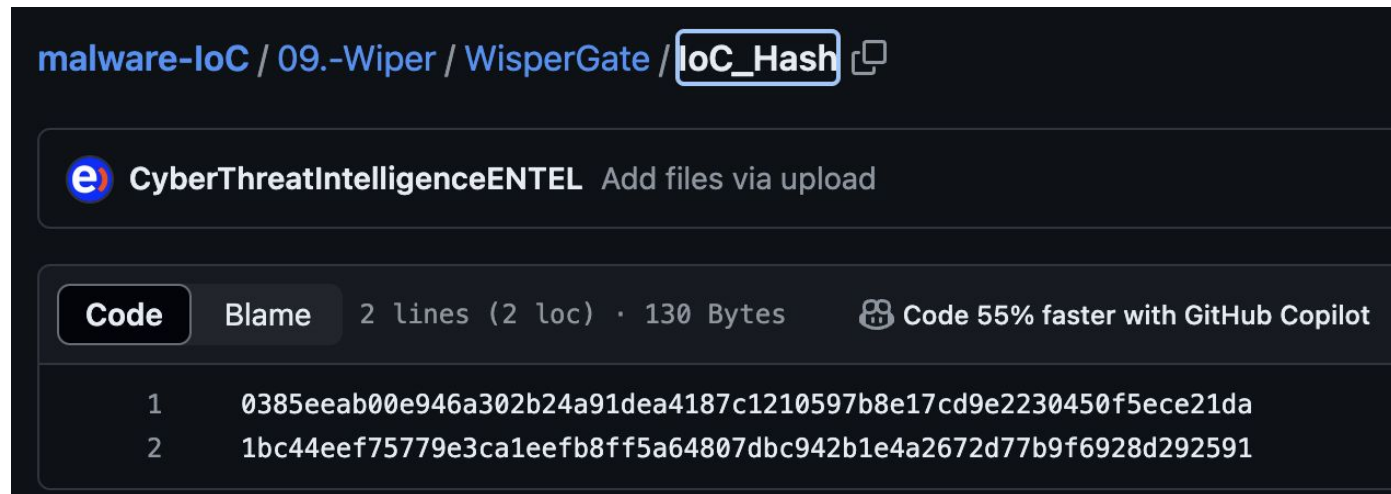
- Fuentes de inteligencia sobre amenazas (Threat Intel):
 - Proveen información de fuentes internas o externas que ayudan al motor de políticas a tomar las decisiones de acceso.
 - Puede tratarse de múltiples servicios que toman datos de fuentes internas o diversas externas e informan sobre nuevos ataques o vulnerabilidades descubiertos.



Componentes de ZTA

- Fuentes de inteligencia sobre amenazas (Threat Intel)

```
#  
#  
#  
# Binary Defense Systems Artillery  
# https://www.binarydefense.com  
#  
# Note that this is for public use  
# The ATIF feed may not be used for  
# Use of these feeds for commercial  
#  
#  
#  
1.15.172.243  
5.182.210.6  
8.219.52.40  
8.219.191.177  
8.222.182.6  
18.142.245.51  
24.209.124.11  
45.55.66.199  
45.227.254.55  
47.181.154.27  
47.236.233.135  
47.236.238.70  
47.236.244.138  
47.236.255.177  
47.237.6.74  
47.237.20.30
```



The screenshot shows a GitHub repository interface. The breadcrumb path is 'malware-loC / 09.-Wiper / WisperGate / loC_Hash'. The file is owned by 'CyberThreatIntelligenceENTEL' and has an 'Add files via upload' button. The file is 130 bytes and consists of 2 lines of code. The code is displayed in a dark-themed editor with line numbers 1 and 2. Line 1 contains the hexadecimal string '0385eeab00e946a302b24a91dea4187c1210597b8e17cd9e2230450f5ece21da' and line 2 contains '1bc44eef75779e3ca1eeffb8ff5a64807dbc942b1e4a2672d77b9f6928d292591'. A badge indicates 'Code 55% faster with GitHub Copilot'.

```
malware-loC / 09.-Wiper / WisperGate / loC_Hash  
CyberThreatIntelligenceENTEL Add files via upload  
Code Blame 2 lines (2 loc) · 130 Bytes Code 55% faster with GitHub Copilot  
1 0385eeab00e946a302b24a91dea4187c1210597b8e17cd9e2230450f5ece21da  
2 1bc44eef75779e3ca1eeffb8ff5a64807dbc942b1e4a2672d77b9f6928d292591
```

<https://github.com/hslatman/awesome-threat-intelligence>

Componentes de ZTA

- Fuentes de inteligencia sobre amenazas (Threat Intel)

62
/ 75

Community Score

62/75 security vendors flagged this file as malicious

Reanalyze Similar More

1bc44eef75779e3ca1eefb8ff5a64807dbc942b1e4a2672d77b9f6928d292591
220522-ny66tadcdj.exe

Size
114.26 KB

Last Analysis Date
14 days ago

EXE

peexe long-sleeps detect-debug-environment overlay checks-disk-space revoked-cert direct-cpu-clock-access signed runtime-modules checks-user-input cve-2014-3931 exploit

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY 30 +

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label trojan.hermeticwiper/killdisk

Threat categories trojan

Family labels hermeticwiper killdisk dangeroussig

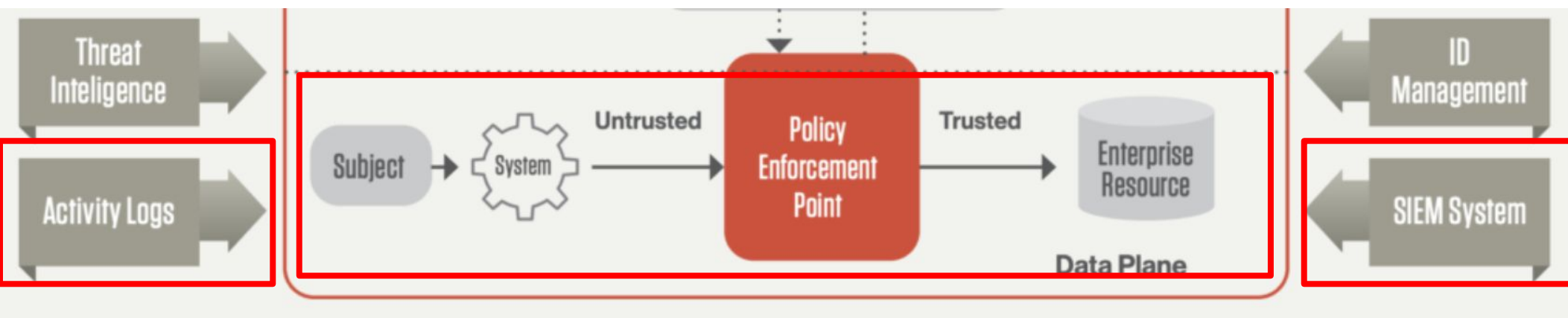
Security vendors' analysis ⓘ

Do you want to automate checks?

AhnLab-V3	! Trojan/Win.Hermeticwiper.R474255	Alibaba	! Trojan:Win32/HermeticWiper.a
ALYac	! Trojan.Agent.Wiper	Antiy-AVL	! Trojan/Win32.Unit8200
Arcabit	! Trojan.HermeticWiper.A	Avast	! Win32:DangerousSig [Trj]
AVG	! Win32:DangerousSig [Trj]	Avira (no cloud)	! TR/HermeticWiper.AM
BitDefender	! Trojan.HermeticWiper.A	Bkav Pro	! W32.AIDetectMalware
ClamAV	! Win.Malware.HermeticWiper-9940039-0	CrowdStrike Falcon	! Win/malicious_confidence_100% (W)

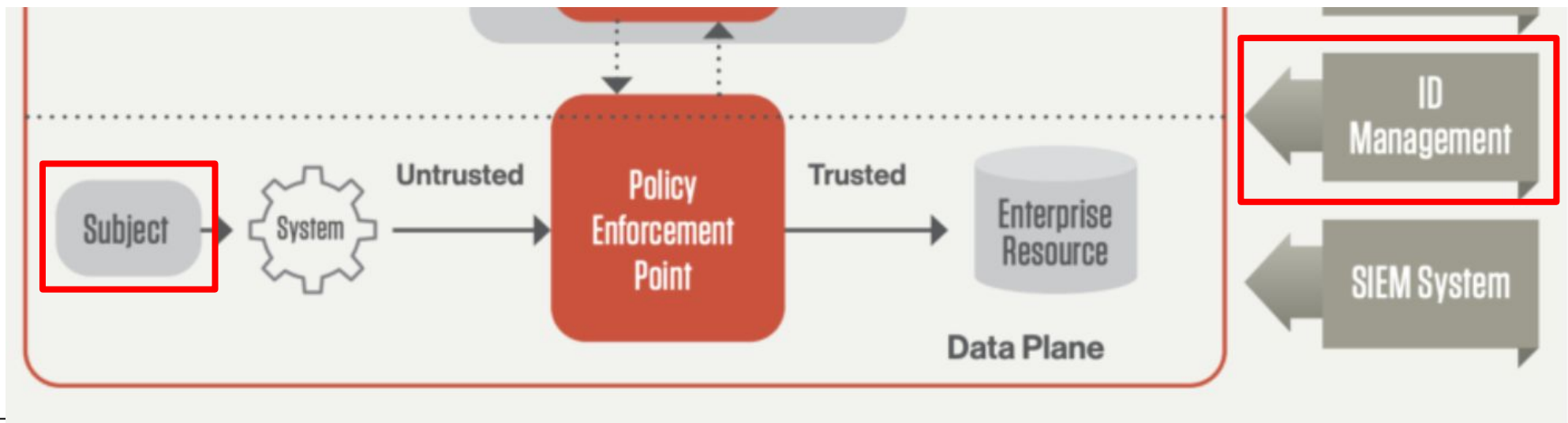
Componentes de ZTA

- Registros (logs) de actividad de la red y del sistema:
 - Recopila los registros de activos, el tráfico de red, las acciones de acceso a los recursos y otros eventos que proporcionan información en tiempo real (o casi) sobre la postura de seguridad de los sistemas de información.
- Sistema de seguridad de la información y gestión de eventos (SIEM, por Security Information and Event Management):
 - recoge información basada en la seguridad para su posterior análisis.



Componentes de ZTA

- Sistema de gestión de identidades
 - Crea, almacena y gestiona las cuentas de usuario de la empresa y los registros de identidad
 - Contiene la información del sujeto (como el nombre, email y los certificados) y otras características relacionadas con la empresa, como la función, los privilegios de acceso y los derechos asignados.



Componentes de ZTA

- Infraestructura de clave pública (PKI, public key infrastructure)
 - este sistema es responsable de generar y registrar los certificados emitidos por la empresa a los recursos, los sujetos, los servicios y las aplicaciones.
- Políticas de acceso a los datos:
 - constituyen las características, reglas y políticas sobre el acceso a los recursos.
 - Este conjunto de normas puede ser codificado (a través de la interfaz de gestión) o generado de manera dinámica por el PE y constituyen el punto de partida para autorizar el acceso a un recurso.



ZTA en el mundo real

- Azure:
 - <https://learn.microsoft.com/en-us/azure/security/fundamentals/zero-trust>
- AWS
 - <https://docs.aws.amazon.com/prescriptive-guidance/latest/strategy-zero-trust-architecture/zero-trust-principles.html>
- Linux RedHat
 - <https://www.redhat.com/en/resources/rhel-for-zero-trust-architectures-ebook>
- Windows Server
 - <https://www.microsoft.com/en-us/security/business/zero-trust>



Criptografía y Seguridad

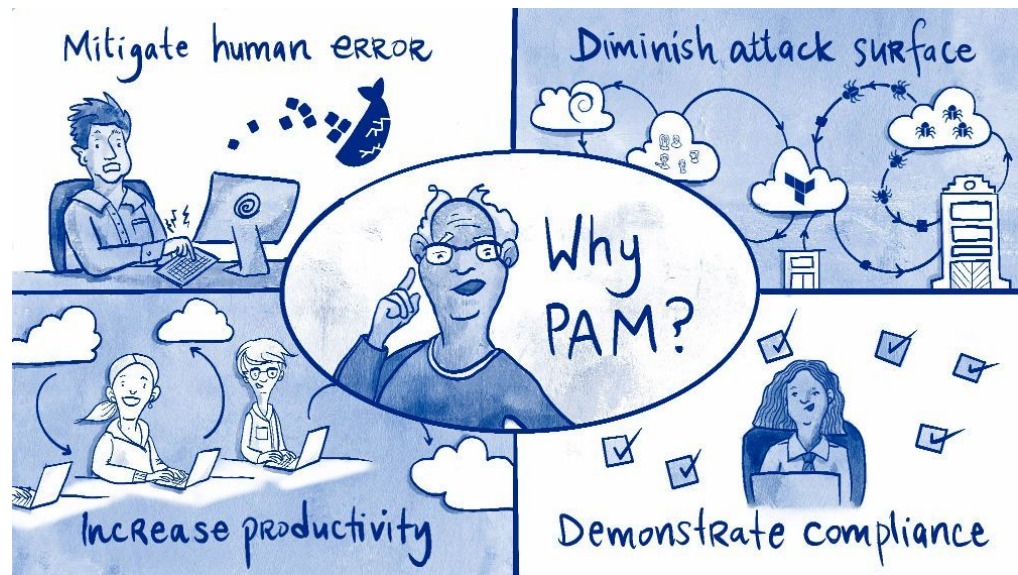
Privileged Access
Management (PAM)

Privileged Access Management, PAM

Se utiliza para proteger y gestionar el uso de cuentas especiales en una organización que tienen acceso privilegiado a sistemas críticos.

Estos accesos privilegiados son especialmente sensibles porque pueden:

- conceder a los usuarios capacidades amplias,
- modificar configuraciones de seguridad,
- acceder a datos confidenciales y
- supervisar otras cuentas de usuario.



Privileged Access Management, PAM

Para gestionar el acceso privilegiado, se emplean varias prácticas y herramientas:

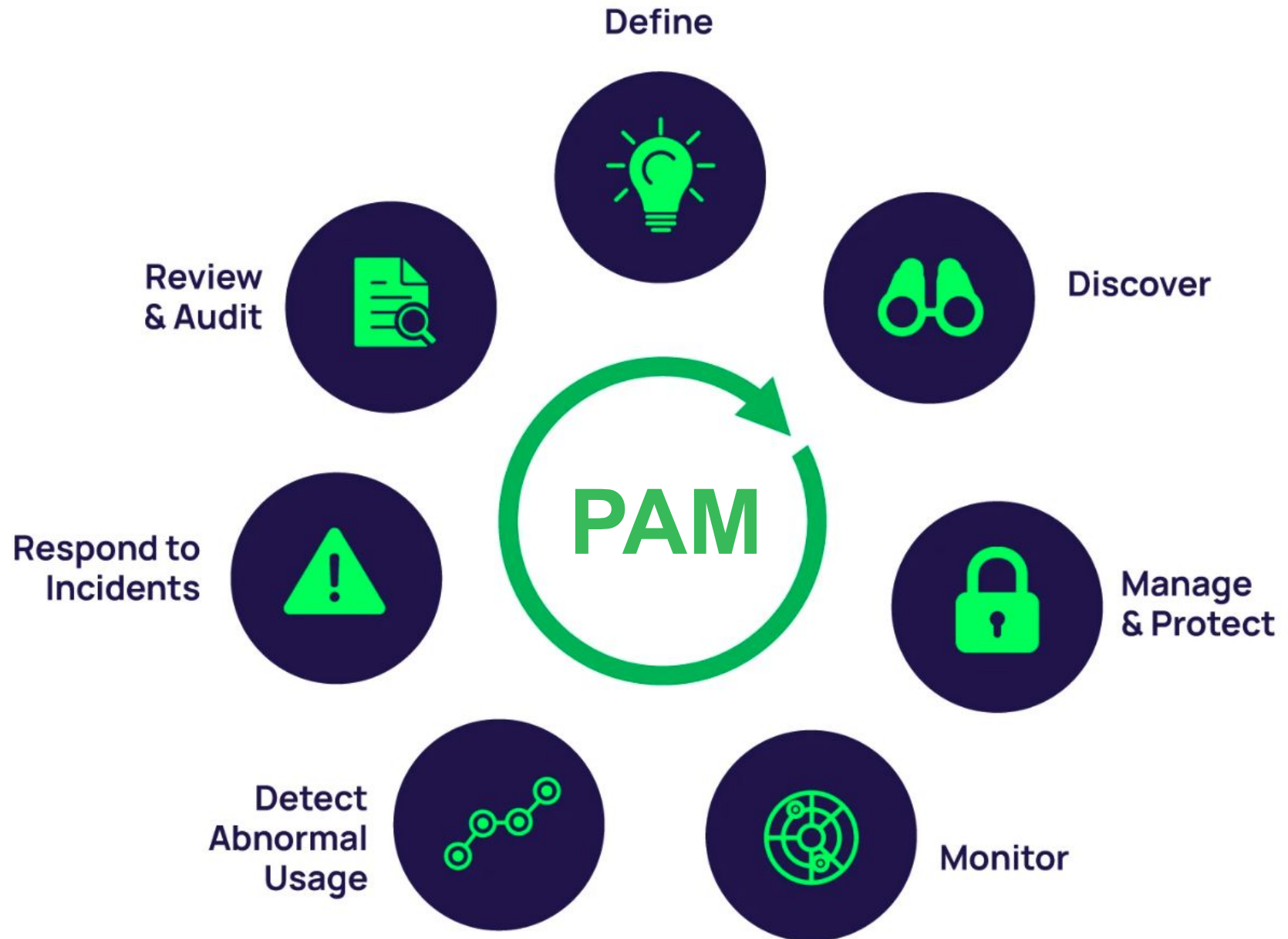
1. Inventario de cuentas privilegiadas: Se debe realizar un inventario de todas las cuentas que tienen acceso privilegiado para asegurar la visibilidad y el control.
2. Principio de privilegio mínimo: Se establece que los usuarios deben tener el mínimo acceso necesario para realizar su trabajo.
3. Autenticación multifactor (MFA): Se recomienda emplear métodos de autenticación multifactor para garantizar que solo los usuarios autorizados puedan acceder a las cuentas privilegiadas y **el no repudio**.

Privileged Access Management, PAM

Para gestionar el acceso privilegiado, se emplean varias prácticas y herramientas:

4. Registro y monitoreo: Se registran y monitorean todas las actividades realizadas con cuentas privilegiadas para detectar y responder a actividades sospechosas.
5. Rotación de contraseñas: Las contraseñas de las cuentas privilegiadas se deben cambiar regularmente y de manera automática para reducir el riesgo de compromisos prolongados.

PAM Life cycle



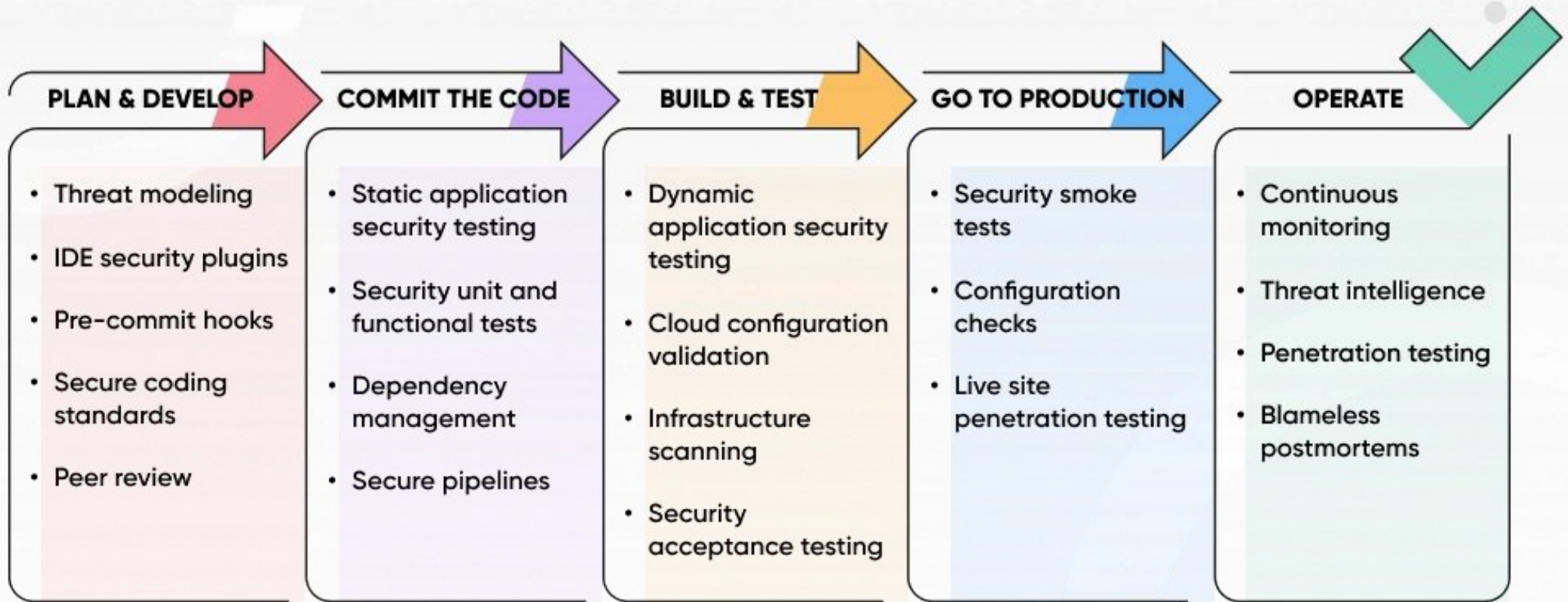


Criptografía y Seguridad

Prevención de
Vulnerabilidades

DevSecOps

What is DevSecOps methodology?

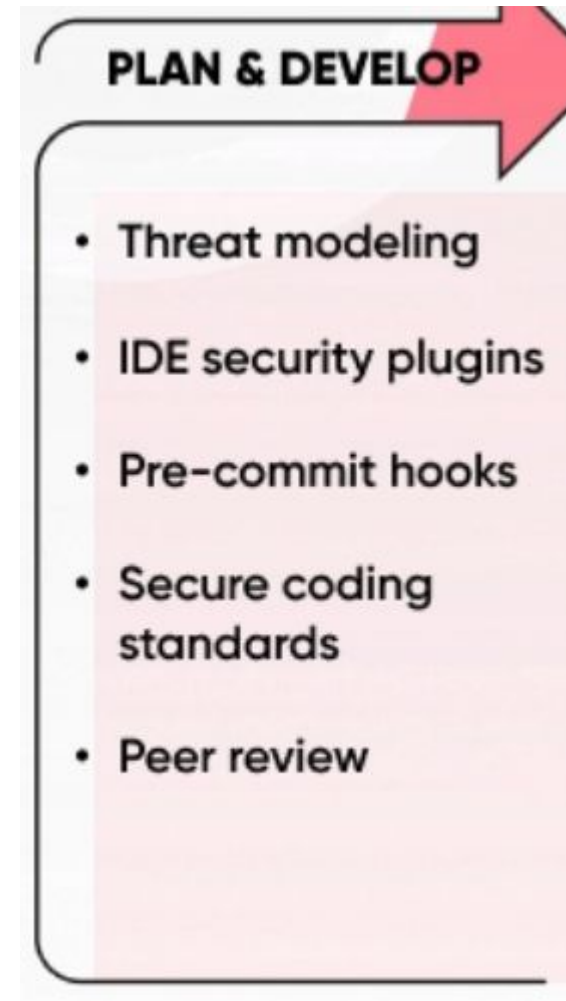


Shift Left

DevSecOps

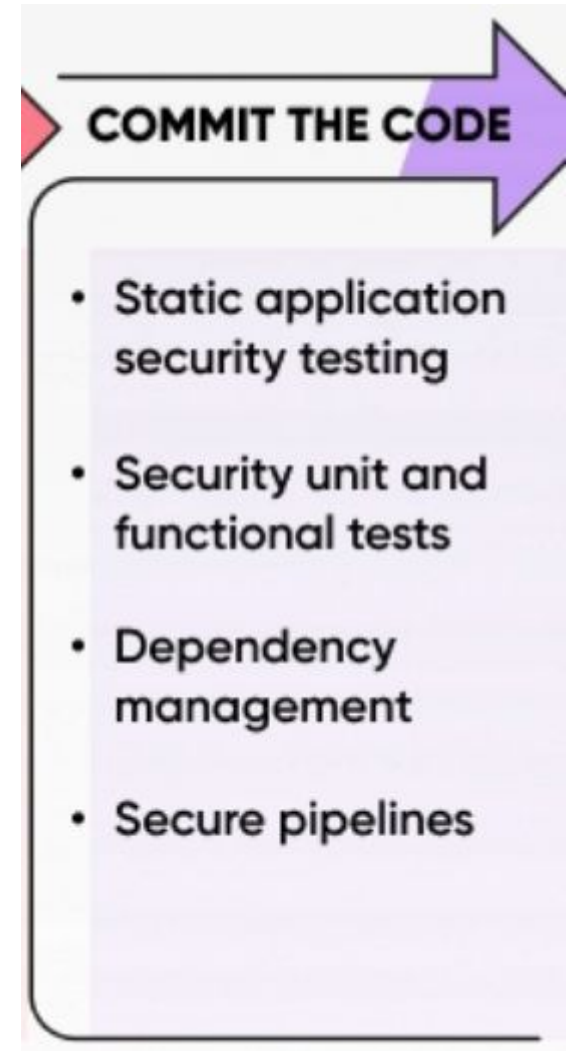
- Planeamiento & Desarrollo

- Aplican todos los principios de seguridad que hablamos hace un par de clase.
- Uso asistentes de AI en el desarrollo de código seguro.
- Forzar controles antes de hacer un commit (pre-commit hooks).
- Aplicar mejores prácticas de desarrollo. Entrenarse en desarrollo seguro.
- Revisión de PRs
- Revisión de vulnerabilidades y correcciones realizadas.



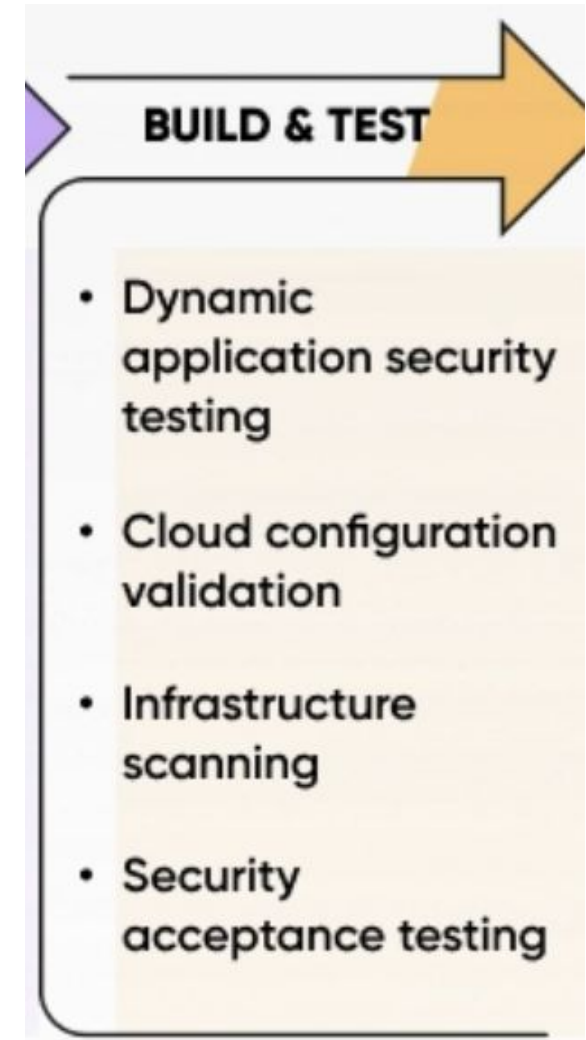
DevSecOps

- On Commit/PR
 - Controles automatizados que se van a aplicar antes de que el código continúe el proceso de deployment.
 - Unit test específico de seguridad: Foco en los CWE.
 - Control de las vulnerabilidad identificadas en las dependencias.
 - Protección de pipelines resguardando acceso a recursos confidenciales, o protección de claves de seguridad.



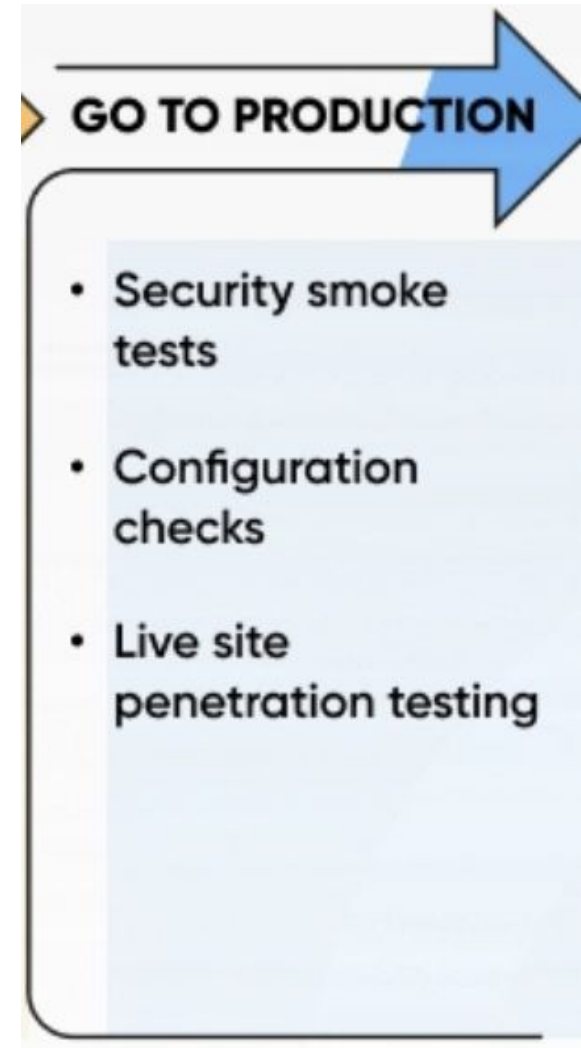
DevSecOps

- On Build/Test
 - Controles dinámicos de código. Se ejecutan partes o la totalidad del código por medio de la interfaces (APIs, URL endpoints, etc...)
 - Validación del código que va a crear recursos en la nube (Infraestructura como código, IaC).
 - Controles de configuración una vez que los códigos de IaC hayan corrido.
 - Evaluación de seguridad de la aplicación como un todo. Ejecución de ataques.



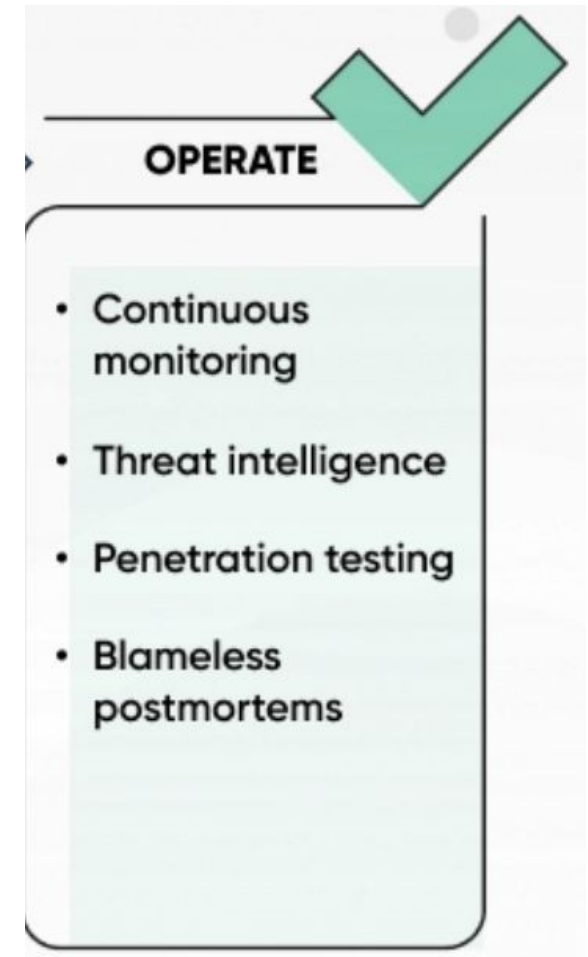
DevSecOps

- On Deployment
 - Evaluación de seguridad de la aplicación como un todo, incluyendo el ambiente de despliegue (Firewalls, WAF, IPS, etc.).
 - Controles sobre artefactos consumidos durante el despliegue (configuraciones, secretos).
 - Test de penetración externos.
 - Red/Blue team.



DevSecOps

- On Operation
 - Monitoreo continuo de métricas y logs de seguridad.
 - Integración con Threat Intelligence.
- Blind Penetration Test
- Ejercicios de simulación de incidentes
- Respuesta ante incidentes.



Testeos de seguridad en el código

- DAST

- Evalúan la seguridad de las aplicaciones mientras se ejecutan, interactuando con ellas como lo haría un usuario externo.
- Se centran en identificar vulnerabilidades que se pueden explotar en la red, como errores de validación de entrada y problemas de autenticación.
- Utilizan las interfaces estándares de las aplicaciones.

Testeos de seguridad en el código

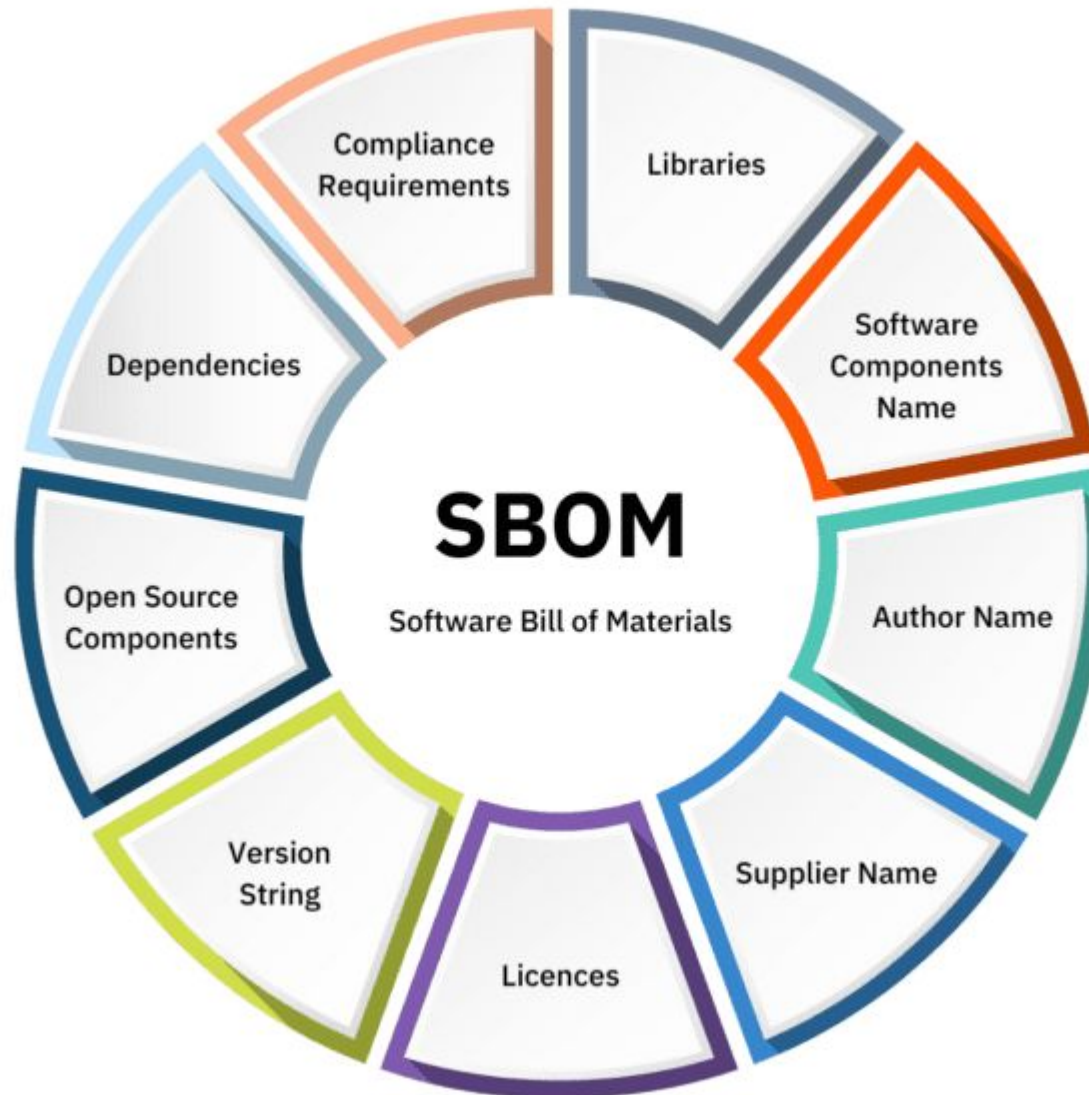
- SCA

- Analizar las dependencias y bibliotecas utilizadas dentro de una aplicación de software para identificar posibles vulnerabilidades de seguridad, problemas de licencia y otros riesgos asociados con estos componentes.
- Debe extenderse a los servicios SaaS consumidos, como versiones de bases de datos online, versiones de APIs o ambientes de ejecución Cloud.

Inventario de software

- Software Bill of Materials (SBOM)
 - Es un inventario formal y legible por máquina de componentes de software y dependencias, información sobre esos componentes y sus relaciones.
 - El inventario de un SBOM debe ser lo más completo posible y debe indicar explícitamente dónde no se pueden articular las relaciones.
 - Deben incluir software de código abierto o con licencia comercial y pueden estar ampliamente disponibles o tener acceso restringido para proteger información confidencial o de propiedad exclusiva.

Inventario de software



Protección de la nube

- Ya hablamos del modelo de seguridad para la nube.
- La configuración es responsabilidad del cliente.
- El uso de infraestructura como código permite definir en una forma reproducible la configuración de la nube.

```
resource "aws_instance" "example_server" {  
    ami          = "ami-04e914639d0cca79a"  
    instance_type = "t2.micro"  
  
    tags = {  
        Name = "JacksBlogExample"  
    }  
}
```

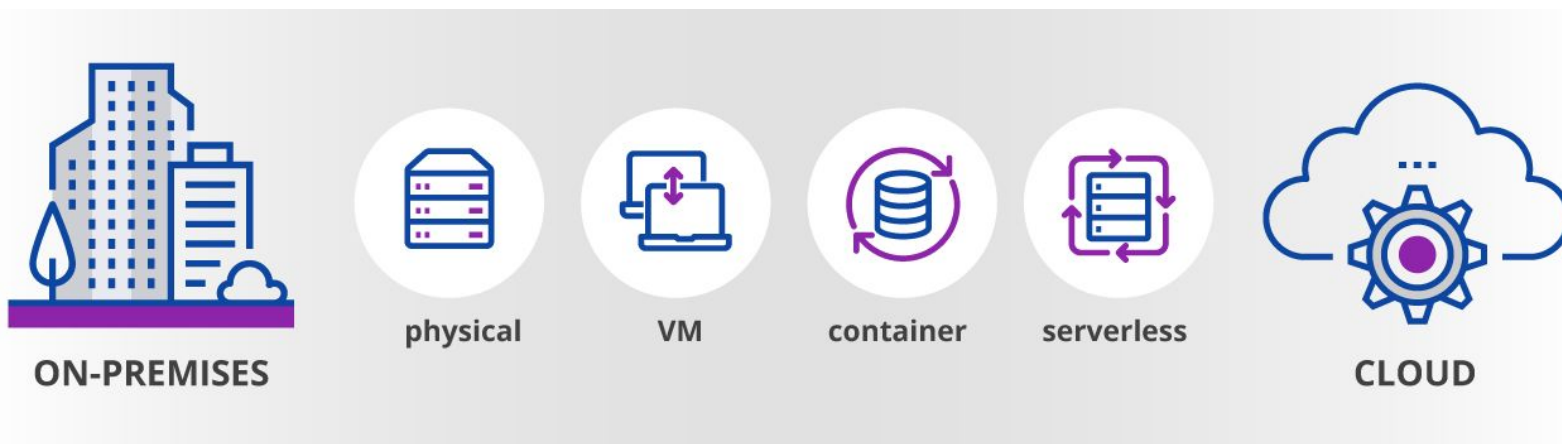
CSPM

- Cloud Security Posture Management (CSPM) busca problemas de configuración y permisos.
- Analiza IaC antes de que sea desplegado.
- Revisa la configuración actual para ver que no habido cambios.



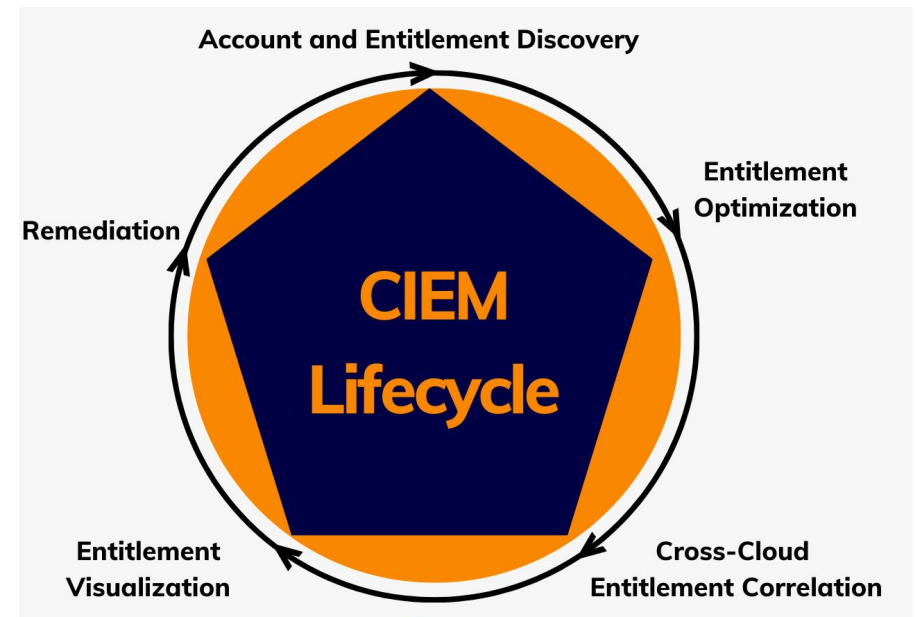
CWSS

- Cloud Workflow Protection Platform (CWPP) se focaliza en la protección de las aplicaciones corriendo en la nube.
- Incluye servidores virtuales, contenedores y serverless.
- Analizar comportamiento, microsegmentación a nivel de contenedores, threat intelligence.
- Complementa a CSPM, que tiene un enfoque más estático.



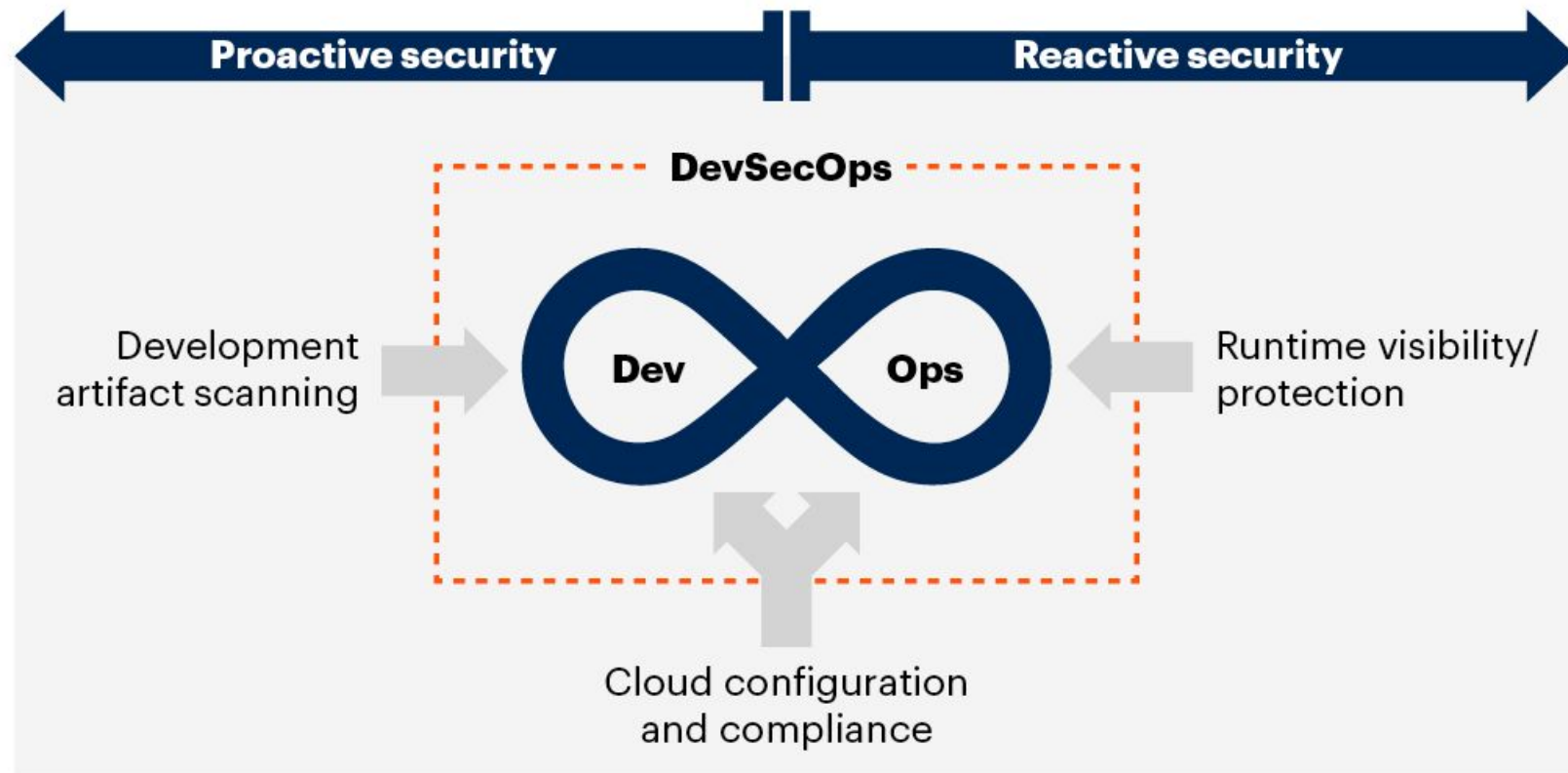
CIEM

- Cloud Infrastructure Entitlement Management (CIEM) tiene foco en los permisos de los sujetos en los recursos de la nube.
- Buscan permisos excesivos
- Compara los registros de uso de los accesos contra los permisos dados, para identificar y remover permisos no utilizados.
- Muestra los permisos y consistencia entre cuentas cloud.
- Permite una visualización efectiva de permisos.



Protección de la nube (CNAPP)

CNAPP Simplified View



Source: Gartner
790337_C

Gartner



Criptografía y Seguridad

Evaluaciones
de seguridad

¿Por qué hacer una evaluación de seguridad?

Security doesn't have to last forever; just longer than everything else that might notice it's gone.

Evaluaciones de seguridad

Existen varios tipos de evaluaciones de seguridad que se utilizan para identificar vulnerabilidades y mejorar la postura de seguridad de una organización.

- **Evaluación de Vulnerabilidades:** Este tipo de evaluación implica el uso de herramientas automatizadas para escanear sistemas y redes en busca de vulnerabilidades conocidas. El objetivo es identificar debilidades que podrían ser explotadas por atacantes.

Evaluaciones de seguridad

- Pruebas de Penetración (Pentesting): A diferencia de las evaluaciones de vulnerabilidades, las pruebas de penetración son más exhaustivas y suelen ser realizadas por expertos en seguridad que intentan explotar vulnerabilidades de manera controlada. Esto ayuda a entender cómo un atacante podría acceder a los sistemas.
- Evaluación de Riesgos: Este proceso implica identificar, evaluar y priorizar riesgos para los activos de información de una organización. Se centra en entender las amenazas y vulnerabilidades, así como en determinar el impacto potencial de los riesgos.

Evaluaciones de seguridad

- Auditoría de Seguridad: Una auditoría de seguridad es una revisión sistemática de las políticas, procedimientos y controles de seguridad de una organización. Puede ser interna o externa y busca asegurar que se cumplan las normativas y estándares de seguridad.
- Evaluación de Cumplimiento: Este tipo de evaluación verifica que una organización cumpla con las regulaciones y estándares de seguridad aplicables, como el GDPR, HIPAA, o PCI-DSS. Se centra en la conformidad con las normativas legales y de la industria.

Evaluaciones de seguridad

- Evaluación de Seguridad Física: Aunque a menudo se pasa por alto, la seguridad física es crucial. Este tipo de evaluación revisa las medidas de seguridad física, como el control de acceso a instalaciones, cámaras de seguridad, y otros mecanismos para proteger los activos físicos.
- Evaluación de Seguridad de Aplicaciones: Se centra en identificar vulnerabilidades en el software y las aplicaciones web. Incluye revisiones de código, pruebas de seguridad de aplicaciones y análisis de arquitectura.

Penetration test (PenTest)

- El objetivo de este tipo de pruebas es la identificación de vulnerabilidades.
- Se realizan con un alcance definido, en tiempo y sistemas evaluados, ya que podrían extenderse indefinidamente.
- Pueden realizarse metódicamente, como un control recurrente para verificar que los controles definidos siguen en su lugar.
- Pueden ejecutarse por un grupo de expertos, para identificar problemas no detectados con anterioridad.

Tipos de PenTest

- Según el grado de visibilidad del evaluador:
 - Black Box Testing: el evaluador no tiene conocimiento previo del sistema o red que está probando. Esto simula un ataque externo donde el atacante no tiene información interna. También se lo denomina Blind Test.
 - White Box Testing: el evaluador tiene acceso completo a la información interna del sistema, como el código fuente, diagramas de red y credenciales. Este enfoque permite una evaluación exhaustiva de las vulnerabilidades internas y es útil para identificar problemas que no serían visibles desde el exterior.

Tipos de PenTest

- Según el grado de visibilidad del evaluador:
 - Gray Box Testing: Este es un enfoque intermedio donde el evaluador tiene algún conocimiento del sistema, pero no acceso completo. Simula un ataque de un usuario con acceso limitado al sistema, como un empleado con privilegios restringidos.
 - Double Blind: Es un ataque BlackBox, donde el atacado tampoco está al tanto del ejercicio de ataque. Se evalúan adicionalmente las capacidades de monitoreo y respuesta del atacado. Es lo más parecido a la realidad.

Tipos de PenTest

- Según el sistema evaluado:
 - Test de Red Externa: Se centra en evaluar la seguridad de los sistemas y servicios expuestos a Internet. El objetivo es identificar vulnerabilidades que podrían ser explotadas por atacantes externos.
 - Test de Red Interna: Evalúa la seguridad de la red interna de una organización. Simula un ataque desde dentro de la organización, como el que podría realizar un empleado descontento o un malware en una estación de trabajo.
 - Test de redes inalámbricas: NFC, Bluetooth, Wireless entre otras.

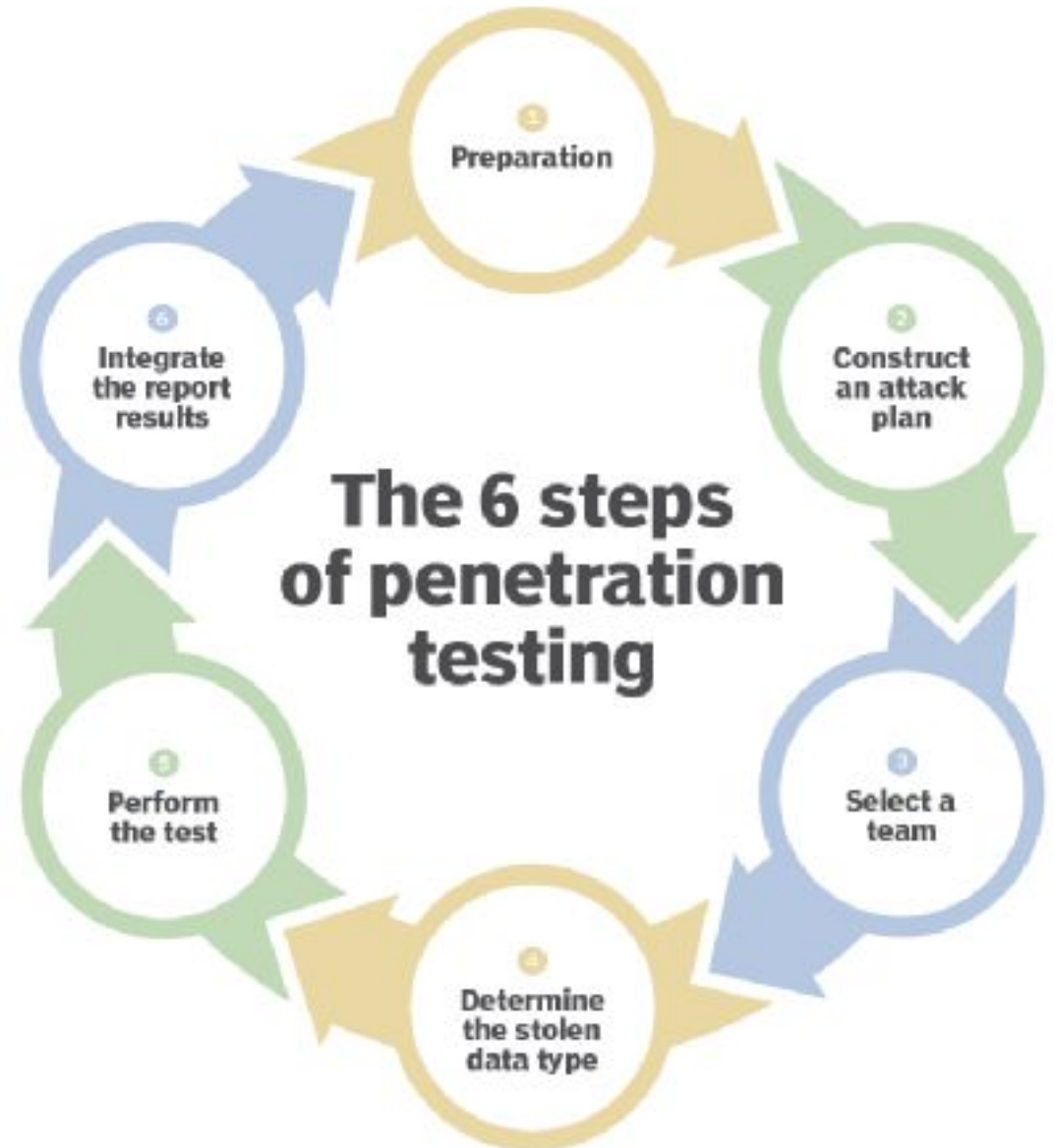
Tipos de PenTest

- Según el sistema evaluado:
 - Test de Aplicaciones Web: Se enfoca en identificar vulnerabilidades en aplicaciones web, como inyecciones SQL, cross-site scripting (XSS), y otros problemas específicos de aplicaciones web.
 - Test de Ingeniería Social: Evalúa la susceptibilidad de los empleados a ser engañados para revelar información confidencial. Esto puede incluir técnicas como phishing o smishing.

Etapas de un PenTest

1. Preparación

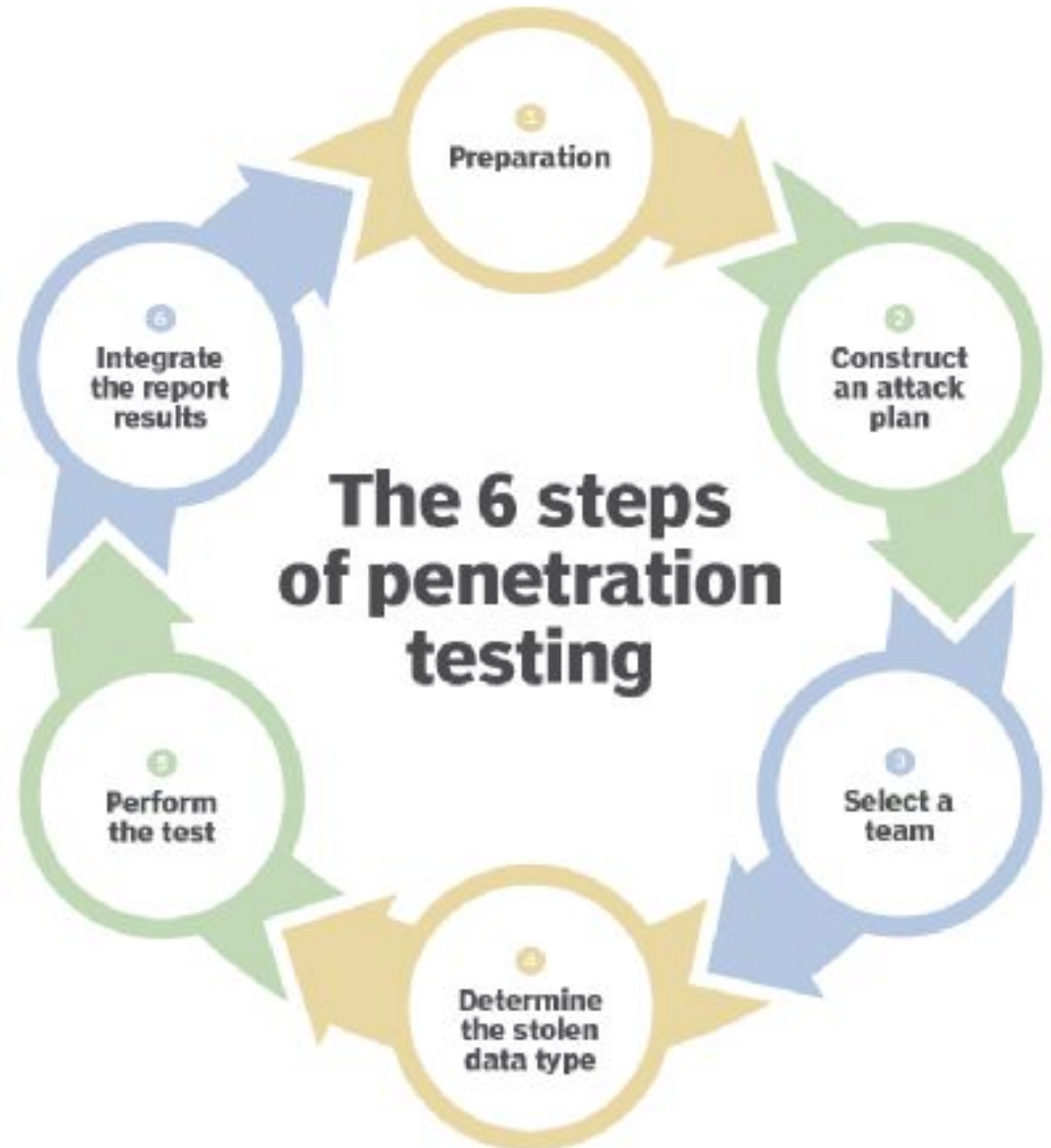
Se identifica el objetivo a evaluar, el alcance de la exploración y se acuerda el nivel de riesgo que la organización desea correr (ejemplo: un ataque de fuerza bruta podría dejar cuentas bloqueadas y afectar sistemas)



Etapas de un PenTest

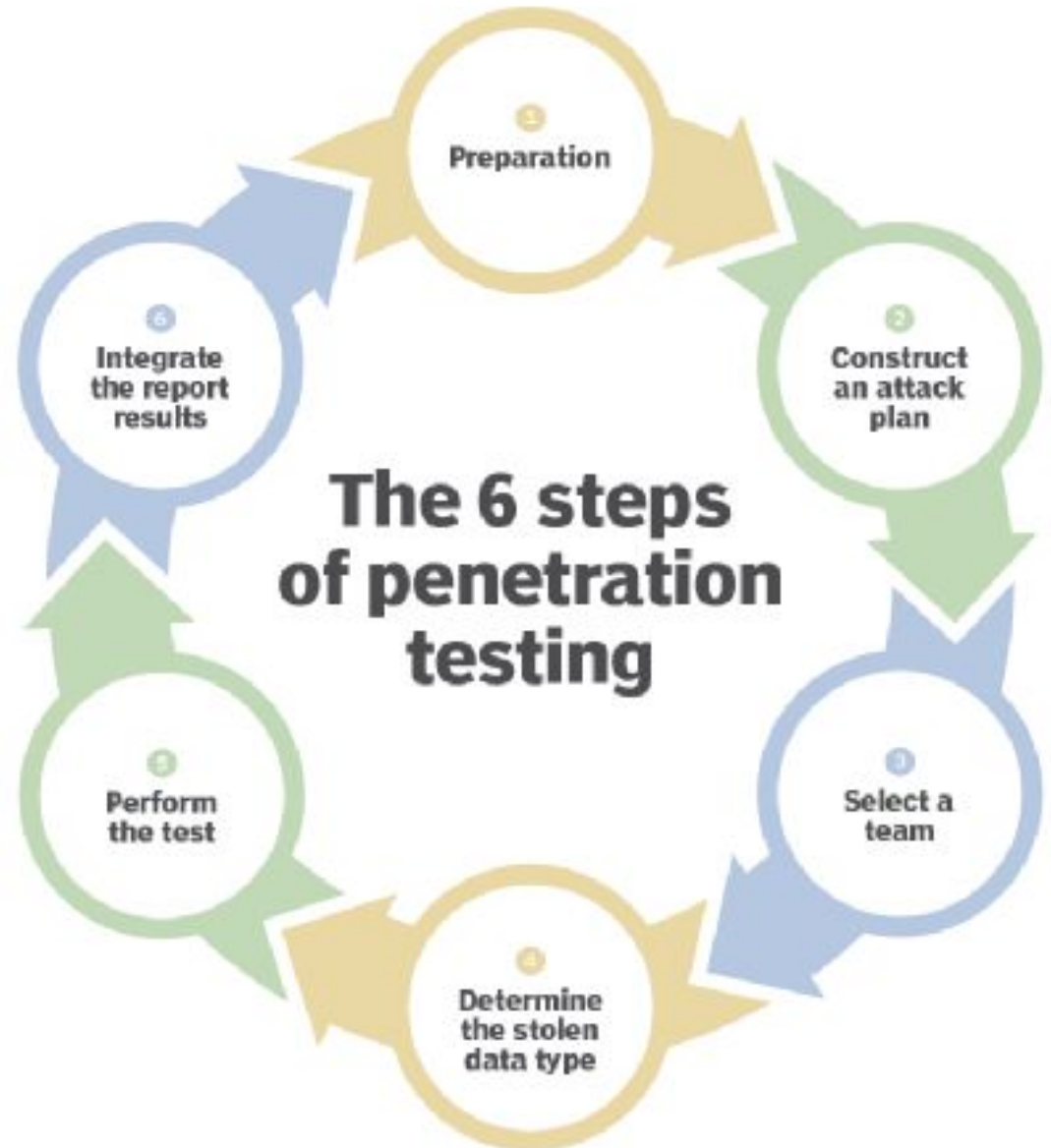
2. Armado del plan de ataque
Definir herramientas a utilizar, ubicación lógica y física desde donde se llevará adelante el ataque.

3. Identificar el equipo de trabajo o profesional para llevar adelante el ataque. Suele haber expertos en distintas tecnologías y generalistas con un poco de conocimiento en todo.



Etapas de un PenTest

4. Definir el objetivo al que se quiere llegar.
Estos ataques suelen ser muy enfocados y muchas veces no aportan información sobre la efectividad del sistema como un todo si no logran el objetivo.
5. Ejecutar el ataque. Esta etapa finaliza con el logro del objetivo o por que se vence el tiempo destinado a pruebas.

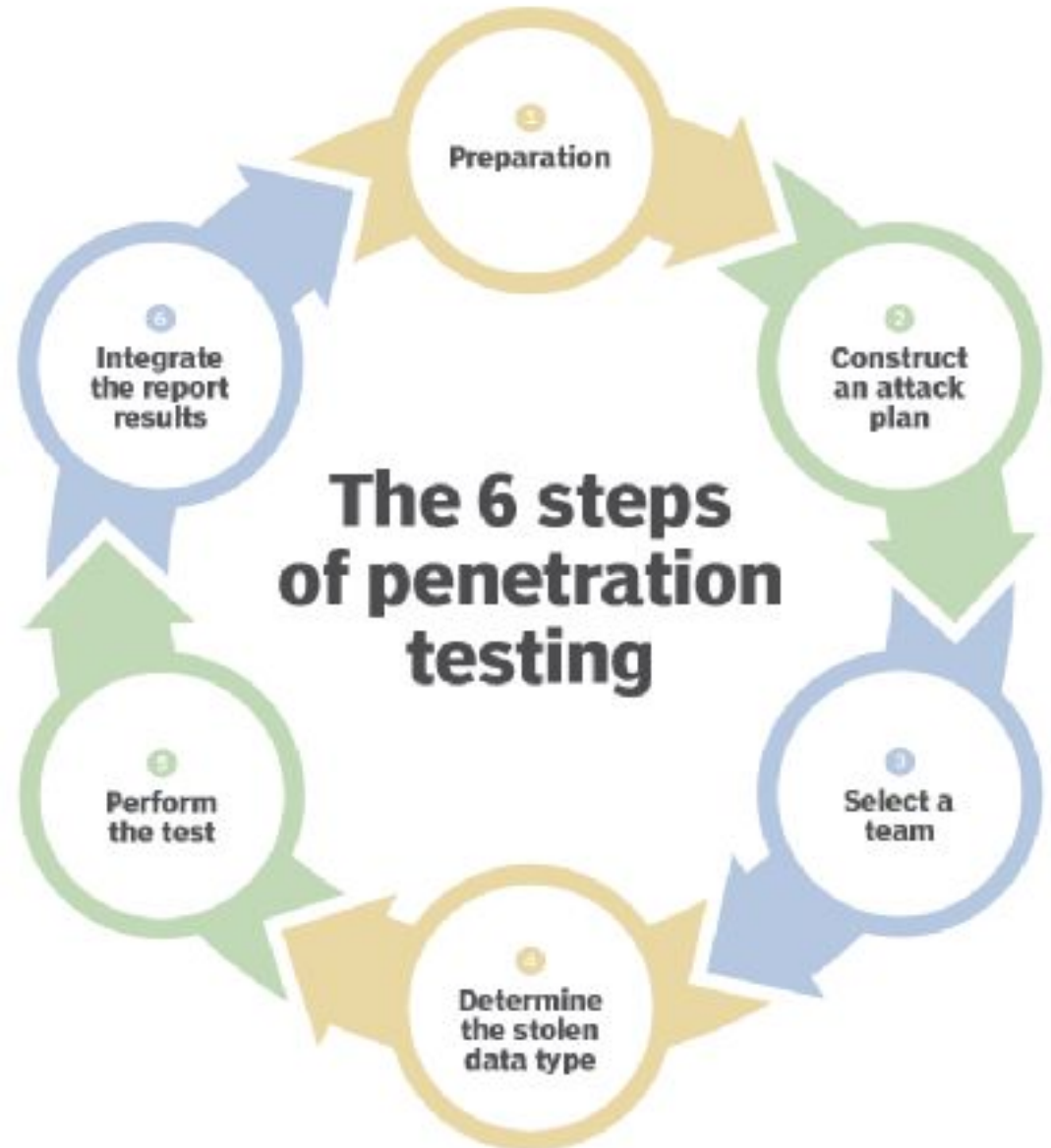


Etapas de un PenTest

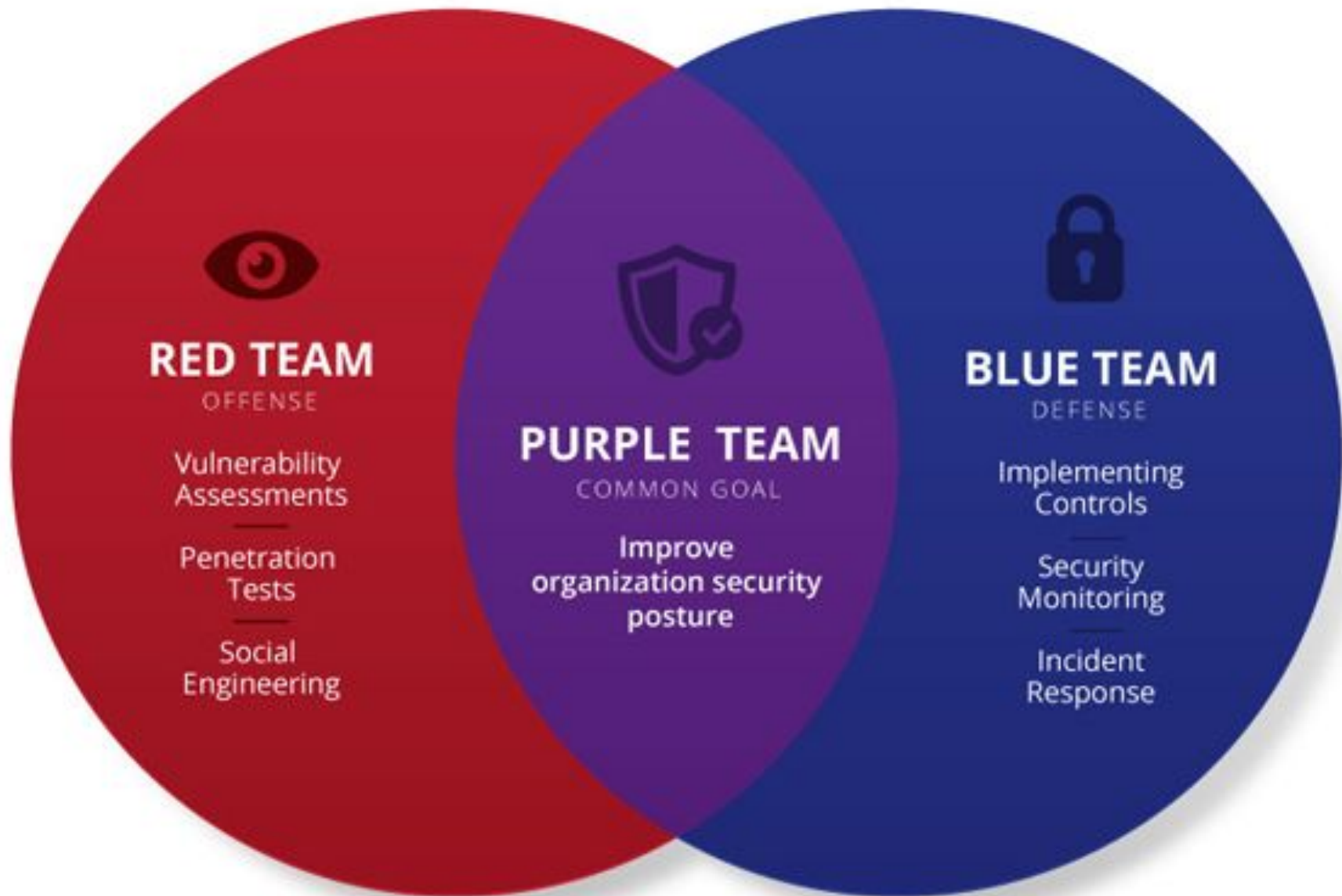
6. Se integran los hallazgos y se comienza nuevamente con el ciclo de pruebas, incorporando los conocimientos o recursos adquiridos durante los ciclos anteriores.

Ejemplo:

1. Se realizar un prueba de ingeniería social
2. Se realizar un ataque de fishing.
3. Con la credenciales se trata de acceder al repositorio de archivos y extraer documentos.



Red/Blue/Purple Team



Red/Blue/Purple Team



El objetivo del Red Team es pensar y actuar como un atacante malintencionado, utilizando diversas técnicas de hacking para comprometer los sistemas, redes y aplicaciones. Las actividades del Red Team son planificadas y ejecutadas de manera controlada para probar la efectividad de las medidas de seguridad existentes y mejorar la capacidad de detección y respuesta de la organización.

Red/Blue/Purple Team

El Blue Team implementa y mantiene medidas de seguridad, como firewalls, sistemas de detección de intrusiones, y prácticas de gestión de parches y configuraciones. También monitorean los sistemas en busca de actividades sospechosas y responden a los intentos de intrusión. El objetivo del Blue Team es proteger los activos de la organización y mitigar los riesgos de ciberataques.



Red/Blue/Purple Team



El Purple Team es un enfoque colaborativo que combina los esfuerzos del Red Team y el Blue Team para mejorar la postura de seguridad de la organización. En lugar de trabajar de manera aislada, el Purple Team fomenta la comunicación y la colaboración entre los equipos ofensivos y defensivos.

Breach and Attack Simulation (BAS)

- Es una categoría de herramientas y técnicas utilizadas para evaluar la efectividad de las defensas de una organización contra posibles ataques.
- Estos ataques simulan las tácticas, técnicas y procedimientos (TTP) que un atacante real podría emplear para comprometer un sistema o red.
- El objetivo principal de las herramientas BAS es identificar vulnerabilidades y brechas de seguridad antes de que puedan ser explotadas por atacantes malintencionados.

Breach and Attack Simulation (BAS)

- El objetivo principal de las herramientas BAS es identificar la capacidad de la organización para identificar y reaccionar ante ataques.
- Se evalúan todas las mismas herramientas que protegen la organización y los sistemas de monitoreo y alertas.
- Identifican cambios de configuración o procesos que dejen de actuar como es esperado.
- Se ejecutan en forma recurrente, probando en distintos puntos de la organización la capacidad de detección, mitigación y respuesta.

Lectura recomendada

Capítulo 2 y 3
NIST 800-207